feat(auth): wajibkan completion username dan password untuk social login
yuda IT authored 5 Nov 2026, 08:32 GMT+7

Social Login Dua Fase (Google & Apple)

Dokumen ini menjelaskan alur final login Google/Apple setelah perubahan **social login = autentikasi saja**. Pembuatan user aktif dan penerbitan token baru dilakukan setelah user melengkapi `username` dan `password`.

Dokumen terkait: `README_APPLE_LOGIN.md` untuk konfigurasi Apple Developer, audience, dan JWKS.

---

1. Prinsip Utama

1. Login social **tidak lagi auto-register** user aktif.
2. User baru dari Google/Apple **tidak dibuatkan row database** sampai completion berhasil.
3. User social lama yang belum lengkap tetap memakai row yang ada, tetapi **dipaksa completion** dan tidak mendapat access/refresh token baru.
4. User social yang sudah lengkap langsung login dan mendapat session.
5. Register/login normal (email/username/phone + password) **tidak berubah**, kecuali username baru sekarang dicek unik secara case-insensitive.
6. Password tetap memakai validasi lama: `required, min=6`. Tambahan satu-satunya adalah batas teknis bcrypt **maksimal 72 byte**.

Akun dianggap **lengkap** jika:

- `username` tidak kosong, dan
- `password` tidak kosong (sudah berupa hash bcrypt di database).

Role user baru adalah `user`, `status = 1`, dan `workflow_state = "active"`.

---

2. Alur Login

2.1 Mobile (Google/Apple)

1. App mengirim ID token ke:
   - `POST /api/user/google/mobile`
   - `POST /api/user/apple/mobile`
2. Backend memvalidasi token provider.
3. Backend mencari user dengan urutan:
   1. provider ID (`google_id` atau `apple_id`),
   2. email terverifikasi.
4. Jika user **sudah lengkap**:
   - backend membuat session,
   - response berisi `user`, `access_token`, `refresh_token`.
5. Jika user **baru atau belum lengkap**:
   - backend **tidak** membuat access/refresh token,
   - response `200` dengan `registration_required: true` dan `registration_token`,
   - app membuka halaman completion dan mengirim `username` + `password` ke endpoint completion.

2.2 Web (Google/Apple)

1. Browser membuka:
   - `GET /api/user/google/login`
   - `GET /api/user/apple/login`
2. Provider redirect ke callback backend:
   - `GET /api/user/google/callback`
   - `POST /api/user/apple/callback` (Apple memakai `response_mode=form_post`)
3. Callback memakai logika yang sama dengan mobile.
4. Jika `SOCIAL_COMPLETION_REDIRECT_URL` diisi dan user perlu completion:
   - backend redirect ke halaman frontend dengan fragment `#ticket=<registration_ticket>`.
5. Jika `SOCIAL_SUCCESS_REDIRECT_URL` diisi dan user sudah lengkap:
   - backend redirect ke halaman sukses frontend dengan fragment `#ticket=<login_ticket>`,
   - frontend menukar ticket tersebut lewat endpoint exchange.
6. Jika URL redirect **kosong**, backend mempertahankan perilaku JSON seperti sebelumnya. Ini menjaga kompatibilitas frontend lama.

> Fragment `#ticket=...` tidak dikirim ke server lain dan tidak masuk access log. Tetap gunakan HTTPS. URL redirect harus memakai path-based routing (mis. `/auth/social/complete`), bukan hash routing (`/#/auth/social/complete`), karena fragment akan dipakai untuk ticket.

---

3. Endpoint

3.1 Completion (wajib untuk user baru/belum lengkap)

```
POST /api/user/auth/social/complete
Content-Type: application/json
```

Body:

```
{
  "ticket": "<registration_token>",
  "username": "budi_123",
  "password": "rahasia",
  "device_id": "device-abc",
  "platform": "android"
}
```

`registration_token` juga diterima sebagai pengganti `ticket`:

```
{
  "registration_token": "<registration_token>",
  "username": "budi_123",
  "password": "rahasia"
}
```

Response sukses:

```
{
  "status": "success",
  "code": "REGISTRATION_COMPLETED",
  "message": "Registrasi berhasil",
  "data": {
    "user": {
      "id": 123,
      "username": "budi_123",
      "email": "budi@example.com",
      "role": "user",
      "status": 1,
      "workflow_state": "active"
    },
    "access_token": "...",
    "refresh_token": "..."
  }
}
```

Efek completion:

- Membuat user baru **atau** memperbarui user social lama yang belum lengkap.
- Mengaitkan provider ID (`google_id` / `apple_id`).
- Menyimpan password sebagai hash bcrypt.
- Mengisi `status = 1`, `workflow_state = "active"`, role `user` (jika masih kosong).
- Menaikkan `token_version` untuk user lama agar session lama tidak dipakai lagi.
- Mencabut refresh token lama user tersebut.
- Menghapus registration ticket (single-use).
- Menerbitkan access/refresh token baru.

3.2 Exchange login ticket (web sukses login)

```
POST /api/user/auth/social/exchange
Content-Type: application/json
```

Body:

```
{
  "ticket": "<login_ticket>",
  "device_id": "browser-abc",
  "platform": "web"
}
```

Response sama seperti login sukses (`user`, `access_token`, `refresh_token`). Login ticket berumur **2 menit**, single-use, dan hanya dibuat jika `SOCIAL_SUCCESS_REDIRECT_URL` diisi.

3.3 Response user baru/belum lengkap

Mobile dan web-fallback JSON:

```
{
  "status": "success",
  "code": "REGISTRATION_REQUIRED",
  "message": "Lengkapi username dan password",
  "data": {
    "registration_required": true,
    "registration_token": "...",
    "expires_in": 600,
    "prefill": {
      "email": "budi@example.com",
      "first_name": "Budi",
      "last_name": "Santoso",
      "full_name": "Budi Santoso",
      "profile_pic": "https://..."
    }
  }
}
```

`prefill` hanya berisi data non-sensitif dari provider. Client **tidak boleh** menganggap `registration_required` sebagai login berhasil dan tidak boleh menyimpan token apa pun sebelum completion.

---

4. Aturan Username

Username wajib:

- panjang **3–30 karakter**,
- hanya huruf, angka, underscore (`_`), dan titik (`.`),
- **tanpa spasi**,
- unik secara **case-insensitive** (`Budi` dan `budi` dianggap sama),
- tidak boleh memakai nama reserved: `admin`, `administrator`, `root`, `system`, `support`, `api`, `www`, `mail`, `help`, `official`, `user`, `guest`, `null`, `undefined`, `ekaplus`, `ekatunggal`.

Username disimpan setelah `trim`. Perbandingan unik memakai kolom `username_normalized` (`LOWER(TRIM(username))`). Kolom ini **nullable** supaya banyak user lama tanpa username tetap valid.

Username lama yang sudah terlanjur mengandung spasi atau karakter lain **tidak diubah otomatis**. Aturan di atas berlaku untuk completion social dan registrasi baru; data lama dibiarkan agar tidak memutus akses user yang sudah ada.

---

5. Aturan Password

- Wajib diisi.
- Minimal **6 karakter** (validasi lama).
- Maksimal **72 byte** karena batas bcrypt.
- Belum ada aturan tambahan uppercase/angka/spasi pada iterasi ini. Ini technical debt yang disepakati.
- Password selalu di-hash dengan bcrypt sebelum disimpan.

---

6. Registration Ticket & Login Ticket

Ticket	TTL	Single-use	Isi
Registration ticket	10 menit	Ya	Provider, provider user ID, email, prefill, token Google (jika web), `user_id` untuk user lama
Login ticket	2 menit	Ya	`user_id` user yang sudah lengkap

- Ticket dibuat dari 32 byte acak dan disimpan di cache/Redis dengan key hash SHA-256.
- Registration ticket maksimal **5 percobaan** completion. Setelah itu ticket dihapus.
- Ticket kedaluwarsa atau tidak valid menghasilkan `INVALID_REGISTRATION_TOKEN`.
- Registration ticket **bukan** access token dan tidak boleh dipakai untuk endpoint terproteksi.

---

7. Aturan Provider

Berlaku sama untuk Google dan Apple:

1. Cari berdasarkan provider ID terlebih dahulu.
2. Jika tidak ditemukan, cari berdasarkan email terverifikasi.
3. Jika email sudah terhubung ke provider ID lain, tolak dengan `SOCIAL_PROVIDER_CONFLICT`.
4. Provider `email_verified` dihormati:
   - email baru harus terverifikasi,
   - email tidak terverifikasi ditolak dengan `EMAIL_NOT_VERIFIED`.
5. Untuk Apple, email bisa tidak dikirim pada login berikutnya. User yang sudah ditemukan lewat `apple_id` tetap boleh login; completion tetap menggunakan email yang tersimpan.
6. Konflik provider tidak pernah menimpa akun yang sudah terhubung ke provider lain.

---

8. Perubahan Database

8.1 Kolom `username_normalized`

Model `users` mendapat kolom nullable:

```
username_normalized VARCHAR(255) NULL
```

Mapper mengisi nilainya otomatis dari `LOWER(TRIM(username))`. Username kosong disimpan sebagai `NULL`, bukan string kosong.

8.2 Backfill & unique index

Saat startup `AutoMigrate` menjalankan:

1. menambah kolom `username_normalized`,
2. backfill data lama,
3. mengecek duplikat case-insensitive,
4. membuat unique index **hanya jika tidak ada duplikat**:

```
CREATE UNIQUE INDEX ux_users_username_normalized
ON users (username_normalized);
```

Jika masih ada duplikat, index **tidak** dibuat dan backend menulis warning ke log. Aplikasi tetap mengecek unique secara aplikatif, tetapi tanpa DB unique index masih ada race window kecil. Bersihkan duplikat lalu restart service.

Query pengecekan:

```
SELECT username_normalized, COUNT(*) AS total
FROM users
WHERE username_normalized IS NOT NULL
GROUP BY username_normalized
HAVING COUNT(*) > 1;
```

Contoh penanganan (rename, jangan hapus akun sembarangan):

```
-- Lihat user yang bentrok lebih dulu
SELECT id, username, email FROM users
WHERE username_normalized = 'nama_yang_duplikat';

-- Rename salah satu akun secara manual setelah diverifikasi
UPDATE users
SET username = 'nama_yang_duplikat_2'
WHERE id = <id_yang_dipertahankan_perubahannya>;

-- Setelah semua duplikat bersih, restart service agar index dibuat.
```

8.3 User social lama yang belum lengkap

User social lama yang belum punya username/password **tidak dihapus**. Saat startup:

- `token_version` dinaikkan,
- refresh token miliknya dicabut,
- access token lama tetap berlaku sampai exp karena JWT stateless, tetapi tidak bisa diperpanjang,
- saat login social berikutnya mereka dipaksa completion.

Query audit:

```
SELECT id, email, username, google_id, apple_id
FROM users
WHERE (google_id <> '' OR apple_id <> '')
  AND (password IS NULL OR password = '' OR username IS NULL OR TRIM(username) = '');
```

---

9. Konfigurasi Environment

Tambahkan ke `.env` / `.env.dev`:

```
# Kosongkan untuk response JSON (backward-compatible).
# Isi untuk redirect web satu kali pakai.
SOCIAL_COMPLETION_REDIRECT_URL=
SOCIAL_SUCCESS_REDIRECT_URL=
```

Contoh:

```
SOCIAL_COMPLETION_REDIRECT_URL=https://app.example.com/auth/social/complete
SOCIAL_SUCCESS_REDIRECT_URL=https://app.example.com/auth/social/success
```

Frontend harus:

1. membaca `ticket` dari fragment URL,
2. memanggil `/auth/social/complete` atau `/auth/social/exchange`,
3. menghapus fragment ticket dari address bar setelah dibaca.

---

10. Error Code

Code	HTTP	Arti
`REGISTRATION_REQUIRED`	200	User baru/belum lengkap; lanjutkan completion
`INVALID_REGISTRATION_TOKEN`	401	Ticket tidak valid, kedaluwarsa, sudah dipakai, atau melebihi batas percobaan
`ACCOUNT_ALREADY_EXISTS`	409	Username/email sudah dipakai
`INVALID_INPUT`	400	Username/password tidak valid
`SOCIAL_CONFLICT`	409	Provider/akun sudah terhubung ke identitas lain, atau registrasi sudah selesai
`EMAIL_NOT_VERIFIED`	401	Email dari provider belum terverifikasi
`SOCIAL_COMPLETION_FAILED`	500	Kegagalan internal saat completion
`GOOGLE_LOGIN_FAILED`	401	Validasi/login Google gagal
`APPLE_LOGIN_FAILED`	401	Validasi/login Apple gagal
`SOCIAL_PROVIDER_CONFLICT`	409	Provider ID bentrok dengan akun lain

---

11. Kompatibilitas

- Login normal (`/login`), register, OTP, refresh token, dan endpoint lain tidak diubah alurnya.
- `Create` user normal sekarang juga menolak username yang sudah dipakai secara case-insensitive.
- Jika kedua env redirect kosong, endpoint Google/Apple web tetap mengembalikan JSON seperti sebelumnya.
- Mobile selalu memakai JSON, tidak pernah redirect.
- Apple state cookie dan validasi JWKS tidak berubah.

---

12. Testing

Unit test:

```
go test ./...
```

Smoke test manual:

```
# 1. Login social baru -> harus REGISTRATION_REQUIRED, bukan token
curl -X POST https://api.example.com/api/user/google/mobile \
  -H 'Content-Type: application/json' \
  -d '{"id_token":"<google_id_token>","device_id":"test","platform":"android"}'

# 2. Completion
curl -X POST https://api.example.com/api/user/auth/social/complete \
  -H 'Content-Type: application/json' \
  -d '{"ticket":"<registration_token>","username":"budi_123","password":"rahasia","device_id":"test","platform":"android"}'

# 3. Login social ulang -> harus langsung LOGIN_SUCCESS
```

Checklist:

- [ ] User baru tidak muncul di tabel `users` sebelum completion.
- [ ] Completion membuat user dengan `status=1`, `workflow_state=active`, role `user`.
- [ ] Username duplikat case-insensitive ditolak.
- [ ] Username dengan spasi/karakter terlarang ditolak.
- [ ] Password <6 dan >72 byte ditolak.
- [ ] Ticket tidak bisa dipakai dua kali.
- [ ] User lama belum lengkap tidak mendapat token sebelum completion.
- [ ] Google dan Apple memakai aturan lookup/konflik yang sama.
- [ ] Callback web redirect membawa ticket di fragment, bukan query string.
- [ ] Normal login/register tetap berjalan.